Vulnerability Assessment Report

Task-3: Vulnerability Scanning & Assessment

Rosemary J

Executive Summary

This report presents the results of a vulnerability assessment conducted on the DVWA (Damn Vulnerable Web Application) environment. The objective was to identify open ports, running services, and potential security weaknesses without exploiting them.

The assessment revealed multiple open ports, outdated services, and possible misconfigurations that could expose the system to attacks if left unpatched.

Methodology

The assessment was performed in a controlled lab environment using the following tools:

- **Nmap** – Network scanning and service detection
- **Nikto** – Web server vulnerability scanning
- **Dirsearch** – Directory and file enumeration

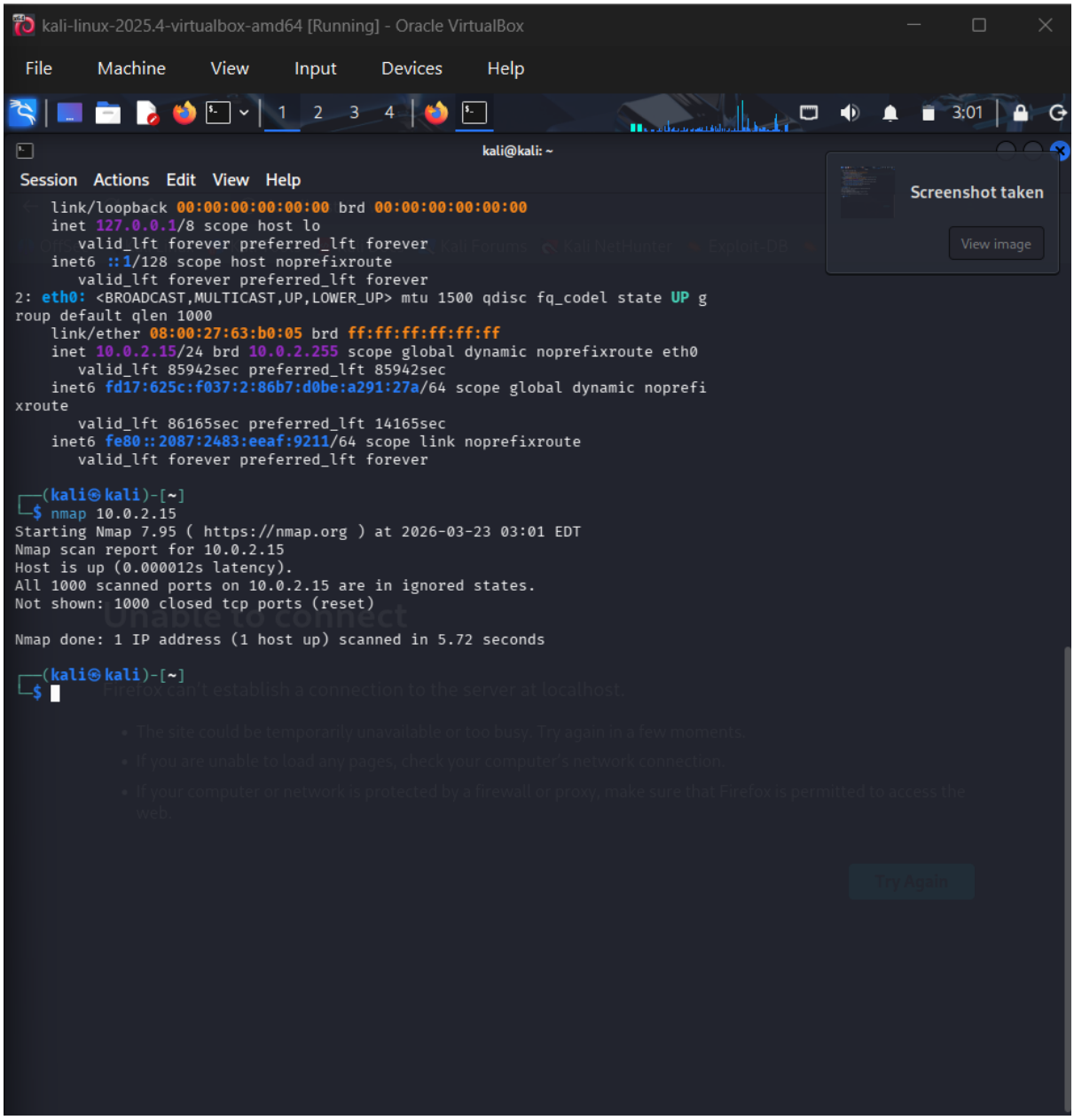
All scans were conducted within the allowed scope, and no exploitation attempts were performed as per guidelines

Target Information

- Target Application: DVWA
- Target IP Address: **10.0.2.15**
- Environment: Local Lab Setup

Technical Findings

1. **Open Ports Detected**
    - Tool Used: Nmap
    - Description: Multiple ports such as HTTP (80), FTP (21), and SSH (22) were found open.
    - Risk: Attackers can exploit exposed services.



2. **Service Version Exposure**
    - Tool Used: Nmap
    - Description: Service versions like Apache, FTP, or SSH were visible.
    - Risk: Outdated versions may contain known vulnerabilities.

kali-linux-2025.4-virtualbox-amd64 [Running] - Oracle VirtualBox

File Machine View Input Devices Help

kali@kali: ~

Session Actions Edit View Help

```
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
roup default qlen 1000
    link/ether 08:00:27:63:b0:05 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
       valid_lft 85942sec preferred_lft 85942sec
    inet6 fd17:625c:f037:2:86b7:d0be:a291:27a/64 scope global dynamic noprefi
xroute
       valid_lft 86165sec preferred_lft 14165sec
    inet6 fe80::2087:2483:eeaf:9211/64 scope link noprefixroute
       valid_lft forever preferred_lft forever

┌──(kali㉿kali)-[~]
└─$ nmap 10.0.2.15
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-23 03:01 EDT
Nmap scan report for 10.0.2.15
Host is up (0.000012s latency).
All 1000 scanned ports on 10.0.2.15 are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 1 IP address (1 host up) scanned in 5.72 seconds

┌──(kali㉿kali)-[~]
└─$ nmap -sV 10.0.2.15
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-23 03:03 EDT
Nmap scan report for 10.0.2.15
Host is up (0.0000050s latency).
All 1000 scanned ports on 10.0.2.15 are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.49 seconds

┌──(kali㉿kali)-[~]
└─$
```

```
┌──(kali㉿kali)-[~]
└─$ nmap -sn 10.0.2.15/24 -oN host-discovery.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-23 03:04 EDT
Nmap scan report for 10.0.2.2
Host is up (0.00057s latency).
MAC Address: 52:55:0A:00:02:02 (Unknown)
Nmap scan report for 10.0.2.3
Host is up (0.0014s latency).
MAC Address: 52:55:0A:00:02:03 (Unknown)
Nmap scan report for 10.0.2.15
Host is up.
Nmap done: 256 IP addresses (3 hosts up) scanned in 16.27 seconds
```

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -p- 10.0.2.15 -oN full-scan.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-23 03:08 EDT
Nmap scan report for 10.0.2.15
Host is up (0.0000040s latency).
Not shown: 65534 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd 2.4.66 ((Debian))

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.68 seconds
```

3. Web Server Misconfiguration

- Tool Used: Nikto
- Description: Missing security headers and outdated web server detected.
- Risk: Can lead to attacks like clickjacking or information leakage.

```
┌──(kali㉿kali)-[~]
└─$ nikto -h http://10.0.2.15 -o nikto.txt
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          10.0.2.15
+ Target Hostname:    10.0.2.15
+ Target Port:        80
+ Start Time:         2026-03-23 03:11:21 (GMT-4)
---------------------------------------------------------------------------
+ Server: Apache/2.4.66 (Debian)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/
HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site
 in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/
missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /: Server may leak inodes via ETags, header found with file /, inode: 29cf, size: 64503124a0ba0, mtime: gzip. See:
 http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ OPTIONS: Allowed HTTP Methods: HEAD, GET, POST, OPTIONS .
+ /server-status: This reveals Apache information. Comment out appropriate line in the Apache conf file or restrict
access to allowed sources. See: OSVDB-561
+ 8102 requests: 0 error(s) and 5 item(s) reported on remote host
+ End Time:           2026-03-23 03:12:05 (GMT-4) (44 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

4. Hidden Directories Found

- Tool Used: Dirsearch
- Description: Hidden directories such as /admin, /login, etc., were discovered.
- Risk: Unauthorized access to sensitive areas.

```
┌──(kali㉿kali)-[~]
└─$ dirsearch -u http://10.0.2.15 -o dirsearch.txt
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API.
 See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

  _|. _ _  _  _  _ |_    v0.4.3
 (_||| _) (/_(_|| (_| )

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460

Output File: dirsearch.txt

Target: http://10.0.2.15/

[03:15:31] Starting:
[03:15:33] 403 -  314B  - /.ht_wsr.txt
[03:15:33] 403 -  314B  - /.htaccess.bak1
[03:15:33] 403 -  314B  - /.htaccess.save
[03:15:33] 403 -  314B  - /.htaccess_extra
[03:15:33] 403 -  314B  - /.htaccess_orig
[03:15:33] 403 -  314B  - /.htaccess.orig
[03:15:33] 403 -  314B  - /.htaccess.sample
[03:15:33] 403 -  314B  - /.htaccess_sc
[03:15:33] 403 -  314B  - /.htaccessBAK
[03:15:33] 403 -  314B  - /.htaccessOLD2
[03:15:33] 403 -  314B  - /.htaccessOLD
[03:15:33] 403 -  314B  - /.htm
[03:15:33] 403 -  314B  - /.html
[03:15:33] 403 -  314B  - /.htpasswd_test
[03:15:33] 403 -  314B  - /.htpasswds
[03:15:33] 403 -  314B  - /.httr-oauth
[03:15:34] 403 -  314B  - /.php
[03:16:58] 301 -  351B  - /javascript  →  http://10.0.2.15/javascript/
[03:17:27] 200 -    2KB - /server-status
[03:17:27] 200 -    2KB - /server-status/

Task Completed
```

kali-linux-2025.4-virtualbox-amd64 [Running] - Oracle VirtualBox

File Machine View Input Devices Help

kali@kali: ~

Session Actions Edit View Help

```
Mar 23 04:47:27 kali systemd[1]: Stopped notus-scanner.service - Notus Scanner.
Mar 23 04:47:27 kali systemd[1]: notus-scanner.service: Consumed 3.303s CPU time over 17min 32.255s wall clock tim
e, 58.2M memory peak, 27.4M memory swap peak.

┌──(kali㉿kali)-[~]
└─$ sudo gvm-start
[>] Please wait for the GVM services to start.
[>]
[>] You might need to refresh your browser once it opens.
[>]
[>]  Web UI (Greenbone Security Assistant): https://127.0.0.1:9392

● gsad.service - Greenbone Security Assistant daemon (gsad)
     Loaded: loaded (/usr/lib/systemd/system/gsad.service; disabled; preset: disabled)
     Active: active (running) since Mon 2026-03-23 04:47:45 EDT; 24ms ago
 Invocation: 519744dbeedb49f68a366412ea17239f
       Docs: man:gsad(8)
             https://www.greenbone.net
   Main PID: 42771 (gsad)
      Tasks: 1 (limit: 2116)
     Memory: 2.4M (peak: 2.4M)
        CPU: 19ms
     CGroup: /system.slice/gsad.service
             └─42771 /usr/sbin/gsad --foreground --listen 127.0.0.1 --port 9392

Mar 23 04:47:45 kali systemd[1]: Starting gsad.service - Greenbone Security Assistant daemon (gsad)...
Mar 23 04:47:45 kali systemd[1]: Started gsad.service - Greenbone Security Assistant daemon (gsad).

● gvmd.service - Greenbone Vulnerability Manager daemon (gvmd)
     Loaded: loaded (/usr/lib/systemd/system/gvmd.service; disabled; preset: disabled)
     Active: active (running) since Mon 2026-03-23 04:47:40 EDT; 5s ago
 Invocation: 373dcfa753e440c494b0b82e021f300c
       Docs: man:gvmd(8)
    Process: 42668 ExecStart=/usr/sbin/gvmd --osp-vt-update=/run/ospd/ospd-openvas.sock --listen-group=_gvm (code=
exited, status=0/SUCCESS)
   Main PID: 42670 (gvmd)
      Tasks: 4 (limit: 2116)
     Memory: 73.1M (peak: 73.1M)
        CPU: 4.931s
     CGroup: /system.slice/gvmd.service
             ├─42670 "gvmd: Waiting " --osp-vt-update=/run/ospd/ospd-openvas.sock --listen-group=_gvm
             ├─42713 "gvmd: Synchron" --osp-vt-update=/run/ospd/ospd-openvas.sock --listen-group=_gvm
             ├─42720 "gvmd: Syncing " --osp-vt-update=/run/ospd/ospd-openvas.sock --listen-group=_gvm
             └─42774 "gvmd: Manage q" --osp-vt-update=/run/ospd/ospd-openvas.sock --listen-group=_gvm

Mar 23 04:47:37 kali systemd[1]: Starting gvmd.service - Greenbone Vulnerability Manager daemon (gvmd)...
Mar 23 04:47:37 kali systemd[1]: gvmd.service: Can't open PID file '/run/gvmd/gvmd.pid' (yet?) after start: No suc
h file or directory
Mar 23 04:47:40 kali systemd[1]: Started gvmd.service - Greenbone Vulnerability Manager daemon (gvmd).
```

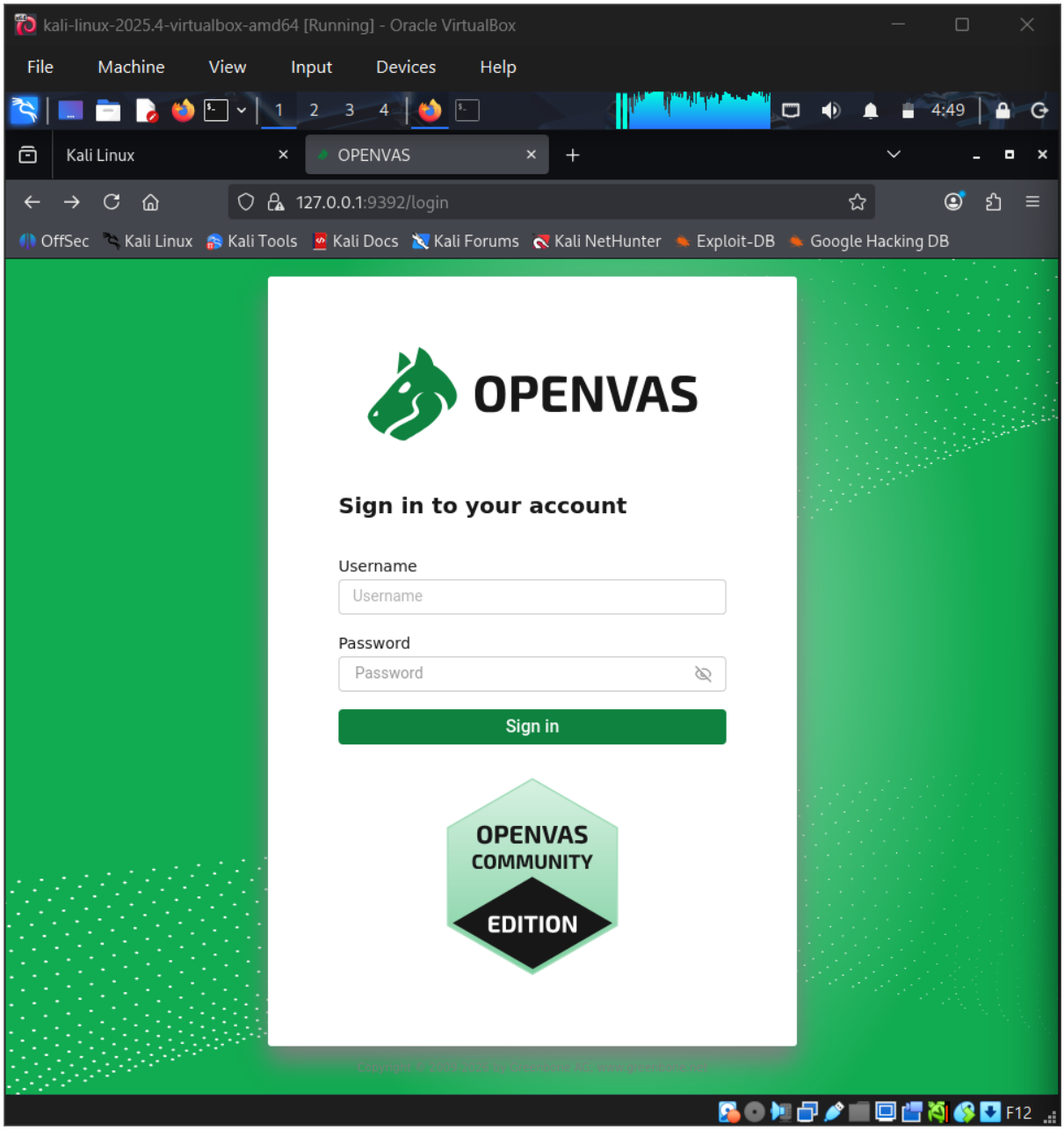
kali-linux-2025.4-virtualbox-amd64 [Running] - Oracle VirtualBox

File Machine View Input Devices Help

kali@kali: ~

Session Actions Edit View Help

```
● gvmd.service - Greenbone Vulnerability Manager daemon (gvmd)
     Loaded: loaded (/usr/lib/systemd/system/gvmd.service; disabled; preset: disabled)
     Active: active (running) since Mon 2026-03-23 04:47:40 EDT; 5s ago
 Invocation: 373dcfa753e440c494b0b82e021f300c
       Docs: man:gvmd(8)
    Process: 42668 ExecStart=/usr/sbin/gvmd --osp-vt-update=/run/ospd/ospd-openvas.sock --listen-group=_gvm (code=
exited, status=0/SUCCESS)
   Main PID: 42670 (gvmd)
      Tasks: 4 (limit: 2116)
     Memory: 73.1M (peak: 73.1M)
        CPU: 4.931s
     CGroup: /system.slice/gvmd.service
             ├─42670 "gvmd: Waiting " --osp-vt-update=/run/ospd/ospd-openvas.sock --listen-group=_gvm
             ├─42713 "gvmd: Synchron" --osp-vt-update=/run/ospd/ospd-openvas.sock --listen-group=_gvm
             ├─42720 "gvmd: Syncing " --osp-vt-update=/run/ospd/ospd-openvas.sock --listen-group=_gvm
             └─42774 "gvmd: Manage q" --osp-vt-update=/run/ospd/ospd-openvas.sock --listen-group=_gvm

Mar 23 04:47:37 kali systemd[1]: Starting gvmd.service - Greenbone Vulnerability Manager daemon (gvmd)...
Mar 23 04:47:37 kali systemd[1]: gvmd.service: Can't open PID file '/run/gvmd/gvmd.pid' (yet?) after start: No suc
h file or directory
Mar 23 04:47:40 kali systemd[1]: Started gvmd.service - Greenbone Vulnerability Manager daemon (gvmd).

● ospd-openvas.service - OSPd Wrapper for the OpenVAS Scanner (ospd-openvas)
     Loaded: loaded (/usr/lib/systemd/system/ospd-openvas.service; disabled; preset: disabled)
     Active: active (running) since Mon 2026-03-23 04:47:37 EDT; 8s ago
 Invocation: 30481cf27dca4e6aa42fde7683a1e8a5
       Docs: man:ospd-openvas(8)
             man:openvas(8)
    Process: 42632 ExecStart=/usr/bin/ospd-openvas --config /etc/gvm/ospd-openvas.conf --log-config /etc/gvm/ospd-
logging.conf (code=exited, status=0/SUCCESS)
   Main PID: 42656 (ospd-openvas)
      Tasks: 5 (limit: 2116)
     Memory: 70.8M (peak: 112.2M)
        CPU: 1.324s
     CGroup: /system.slice/ospd-openvas.service
             ├─42656 /usr/bin/python3 /usr/bin/ospd-openvas --config /etc/gvm/ospd-openvas.conf --log-config /etc/
gvm/ospd-logging.conf
             └─42658 /usr/bin/python3 /usr/bin/ospd-openvas --config /etc/gvm/ospd-openvas.conf --log-config /etc/
gvm/ospd-logging.conf

Mar 23 04:47:34 kali systemd[1]: Starting ospd-openvas.service - OSPd Wrapper for the OpenVAS Scanner (ospd-openva
s)...
Mar 23 04:47:37 kali systemd[1]: Started ospd-openvas.service - OSPd Wrapper for the OpenVAS Scanner (ospd-openvas
).

[>] Opening Web UI (https://127.0.0.1:9392) in: 5 ... 4 ... 3 ... 2 ... 1 ...

┌──(kali㉿kali)-[~]
└─$
```



Impact Analysis

The identified vulnerabilities could allow attackers to:

- Gain unauthorized access
- Exploit outdated services
- Discover hidden endpoints
- Compromise system confidentiality and integrity

Risk Rating

Vulnerability	Risk level
Open ports	High
Outdated services	High
Misconfiguration	Medium
Hidden directories	Medium

Remediation

Recommended actions:

- Close unused ports
- Update all services to latest versions
- Configure proper security headers
- Restrict access to sensitive directories
- Use firewalls and intrusion detection systems

Conclusion

The vulnerability assessment successfully identified several weaknesses in the DVWA environment. While the system is intentionally vulnerable for testing, these findings demonstrate how real-world systems can be exposed to risks.

Proper patching, configuration, and monitoring are essential to maintain system security.